

01

Fundamentos da Segurança da Informação

Princípios, ativos, ciclo de vida da informação, risco e visão da ISO/IEC 27001

Curso Técnico em Desenvolvimento de Sistemas

Capítulo planejado para aproximadamente 4 horas-aula

Material de apoio didático • teoria, laboratório e revisão

Base curricular

Este capítulo foi estruturado a partir das bases tecnológicas do componente Segurança de Sistemas de Informação do curso Técnico em Desenvolvimento de Sistemas do Centro Paula Souza. A coleção expande a ementa com exemplos e atividades de laboratório.

Objetivos de aprendizagem

- Explicar por que segurança da informação não se resume a antivírus ou senhas.
- Distinguir confidencialidade, integridade e disponibilidade e relacioná-las a situações reais.
- Identificar ativos de informação, ameaças, vulnerabilidades, impactos e controles.
- Compreender o papel de políticas, processos e melhoria contínua em um sistema de gestão de segurança.

Alinhamento curricular

Relaciona-se às habilidades de identificar ameaças, implementar técnicas e operar mecanismos de segurança, preparando a base conceitual para os demais capítulos.

1. Segurança da informação no desenvolvimento de sistemas

A segurança da informação protege dados, serviços, pessoas e processos contra eventos que possam causar perda, alteração indevida, exposição ou indisponibilidade. Em desenvolvimento de sistemas, ela deve aparecer desde o levantamento de requisitos até a operação e manutenção do software. Quando a segurança é tratada apenas no final do projeto, correções tendem a ser mais caras e incompletas.

Um sistema pode funcionar perfeitamente do ponto de vista funcional e ainda ser inseguro. Um cadastro que grava corretamente os clientes, por exemplo, pode permitir que qualquer usuário consulte dados de terceiros. Por isso, requisitos funcionais e requisitos de segurança precisam caminhar juntos.

2. Tríade CIA: confidencialidade, integridade e disponibilidade

Confidencialidade significa impedir acesso ou divulgação não autorizada. Integridade significa preservar exatidão, completude e origem confiável da informação. Disponibilidade significa manter informação e serviços acessíveis quando necessários. Os três objetivos podem entrar em tensão: um controle extremamente restritivo pode aumentar confidencialidade, mas prejudicar disponibilidade.

Além da tríade, conceitos como autenticidade, responsabilização, rastreabilidade e não repúdio ajudam a explicar cenários reais. Logs confiáveis, assinaturas digitais e trilhas de auditoria são exemplos de mecanismos que sustentam essas propriedades.

Objetivo	Pergunta prática
Confidencialidade	Quem pode ver esta informação?
Integridade	Quem pode alterar e como detectar alteração indevida?
Disponibilidade	Quanto tempo o serviço pode ficar indisponível?

3. Ativos, ameaças, vulnerabilidades, riscos e controles

Ativo é tudo o que tem valor para a organização: banco de dados, código-fonte, servidor, credencial, documentação, reputação e até conhecimento de pessoas. Ameaça é algo capaz de causar dano. Vulnerabilidade é uma fraqueza que pode ser explorada. Risco combina a possibilidade de um evento com suas consequências.

Um controle de segurança reduz probabilidade, impacto ou ambos. Controles podem ser administrativos, físicos ou técnicos; preventivos, detectivos ou corretivos. Exemplos incluem política de senhas, controle de acesso físico, firewall, backup, monitoramento e plano de resposta a incidentes.

4. Ciclo de vida da informação e classificação

A informação é criada ou coletada, armazenada, utilizada, compartilhada, arquivada e eventualmente descartada. Em cada fase, surgem riscos diferentes. Um arquivo temporário com dados pessoais, por exemplo, pode ser esquecido fora do repositório oficial e permanecer exposto.

A classificação ajuda a decidir o nível de proteção. Uma organização pode usar classes como pública, interna, confidencial e restrita. O nome das classes varia; o importante é definir critérios, responsáveis e controles coerentes para armazenamento, transmissão e descarte.

5. ISO/IEC 27001 em visão prática

A ISO/IEC 27001 estrutura um Sistema de Gestão de Segurança da Informação (SGSI). Para o técnico, o mais importante é entender a lógica: conhecer o contexto, avaliar riscos, escolher controles, definir responsabilidades, medir resultados e melhorar continuamente. A norma não é uma lista de ferramentas obrigatórias; ela organiza gestão e governança.

Em um projeto pequeno, essa lógica pode ser aplicada com um inventário de ativos, uma matriz simples de riscos, controles priorizados, responsáveis e evidências de verificação. O objetivo é transformar segurança de uma coleção de ações isoladas em um processo repetível.

Laboratório e aplicação prática

Prática 1 - Mini análise de risco de uma aplicação escolar

Objetivo: Aplicar os conceitos do capítulo a um sistema fictício de notas e frequência.

1. Liste pelo menos cinco ativos do sistema, incluindo dados, software, infraestrutura e pessoas.
2. Para cada ativo, registre uma ameaça e uma vulnerabilidade plausível.
3. Atribua probabilidade e impacto em escala baixa, média ou alta.
4. Proponha pelo menos um controle preventivo e um controle detectivo para os riscos mais importantes.
5. Revise se algum controle reduz disponibilidade ou usabilidade de forma excessiva.

Entrega sugerida: Uma tabela de riscos com ativo, ameaça, vulnerabilidade, impacto, probabilidade e controles.

Questões de fixação

1. Qual é a diferença entre ameaça e vulnerabilidade? Dê um exemplo.
2. Por que um sistema disponível pode ainda ser inseguro?
3. Como a classificação da informação influencia os controles aplicados?
4. O que muda quando a segurança é tratada como processo de gestão e não apenas como ferramenta?

5. Explique um caso em que aumentar a confidencialidade pode prejudicar a disponibilidade.

Como estudar

Responda primeiro sem consultar o texto. Depois compare sua resposta com o resumo do capítulo e complemente o que faltou.

Resumo do capítulo

- Segurança deve integrar o ciclo de desenvolvimento e operação do sistema.
- Confidencialidade, integridade e disponibilidade formam a base para analisar objetivos de proteção.
- Risco depende de contexto, ameaça, vulnerabilidade, probabilidade e impacto.
- Ativos precisam ser conhecidos e classificados para receber controles adequados.
- A ISO/IEC 27001 oferece uma lógica de gestão baseada em risco e melhoria contínua.

Glossário essencial

Termo	Definição
Ativo	Recurso que possui valor para a organização e precisa de proteção.
Ameaça	Evento, agente ou condição com potencial de causar dano.
Vulnerabilidade	Fraqueza que pode permitir a concretização de uma ameaça.
Risco	Efeito da incerteza sobre objetivos, associado à probabilidade e impacto.
Controle	Medida usada para modificar o risco.
SGSI	Sistema de Gestão de Segurança da Informação.

Referências e materiais de consulta

- Centro Paula Souza. Plano de Curso do Técnico em Desenvolvimento de Sistemas, componente Segurança de Sistemas de Informação.
- CERT.br. Cartilha de Segurança para Internet. Conteúdo de conscientização e boas práticas de segurança.
- ISO/IEC 27001. Sistemas de gestão de segurança da informação - requisitos e princípios de gestão.
- OWASP Foundation. OWASP Top 10:2025 e materiais de segurança de aplicações web.